

Simtec Consult - Data Protection and Retention Policy

Version: 1.3

Status: Approved

Owner: Director

Applies to: employees, contractors, company systems, client data

Related to: Cyber Essentials, UK GDPR, Data Protection Act 2018, Data (Use and Access) Act 2025

Last reviewed: 2026-08-03

Next review due: 2026-10-03

Purpose

Simtec must protect personal data and business data in line with UK GDPR, the Data Protection Act 2018, ICO accountability expectations, customer obligations, and Cyber Essentials security controls.

Policy

Staff and contractors must use personal data only for approved business purposes, collect and retain only what is needed, keep data accurate where Simtec is responsible for it, store data only in approved systems, protect data with access controls, MFA and encryption where available, and report suspected loss, unauthorised access, or accidental disclosure promptly.

Company and client data must be stored only in approved locations such as Google Workspace, approved GitHub repositories, AWS-hosted customer or internal systems, approved customer systems, and approved business cloud services. Staff should avoid local storage of client data unless there is a clear business need, and must delete local copies when no longer required.

Where Simtec hosts a customer application, primary application data, including database records and application files, must be hosted in UK or EEA regions unless a different location is agreed with the customer in writing. Approved suppliers may process account, support, security, traffic, or service metadata elsewhere only where applicable data protection and international transfer requirements are addressed.

Access to personal data must be granted only for a business need, limited by role and project, removed promptly when no longer needed, protected by named accounts and MFA where available, and reviewed when roles, projects, or suppliers change.

Simtec should maintain proportionate records of material personal data processing where it acts as controller or processor. Records should cover purpose, data categories, systems or suppliers, customer or data owner, retention expectation, access groups, and international transfer considerations.

Simtec must provide a way for people to make data protection complaints. Complaints must be acknowledged within 30 days, investigated without undue delay, kept updated where needed, and closed by telling the person the outcome.

Requests to exercise data protection rights, including access, rectification, erasure, restriction, portability, objection, and not being subject to solely automated decisions, must be recorded, checked for identity and authority where needed, assessed promptly, and answered within the applicable UK GDPR deadline. Where Simtec acts as processor, the request must be referred to the relevant customer/controller without undue delay unless Simtec is authorised to respond.

Data must not be kept longer than needed. Accounting, tax, finance, contract and commercial records are generally retained for 6 years unless a longer legal or contractual reason applies. Customer project records, support correspondence, source code, deployment history, recruitment data, security logs, and incident records must be retained only for proportionate business, legal, contractual, audit, support, or lessons-learned reasons.

When data is no longer needed, Simtec must delete, anonymise, or return it using a method appropriate to the system. This may include deleting cloud files, removing local project data, deleting database exports, revoking shared links, and removing repository, deployment, or support access.

New systems, suppliers, and customer features that involve personal data should consider data minimisation, access control, auditability, security updates, backups, secure deletion, and whether a data protection impact assessment is needed.

Suspected personal data breaches must be handled under `policies/incident-response-and-personal-data-breach-plan.md`.

Review

This policy is reviewed annually, when processing changes materially, and after significant data incidents.

Review History

Date	Reviewer	Description	Next review due
2026-08-03	Policy Manager	Added the approved default commitment to host primary customer application data in UK or EEA regions, with written customer agreement required for a different location and safeguards for other supplier processing.	2026-10-03
2026-07-03	Policy Manager	Added concise data-subject-rights handling because the weekly review found a material UK GDPR process gap for a firm handling customer and CRM personal data.	2026-10-03
2026-06-22	Policy Manager	Added ICO data protection complaints handling requirements.	2026-09-22
2026-06-03	Policy Manager	Created current policy document aligned to Simtec requirements and relevant Cyber Essentials answers.	2026-09-03